

AWS STS e AssumeRole

Credenciais Temporárias e Acesso Cross-Account

AWS Certified Developer Associate

Instrutor: Marlon Anesi

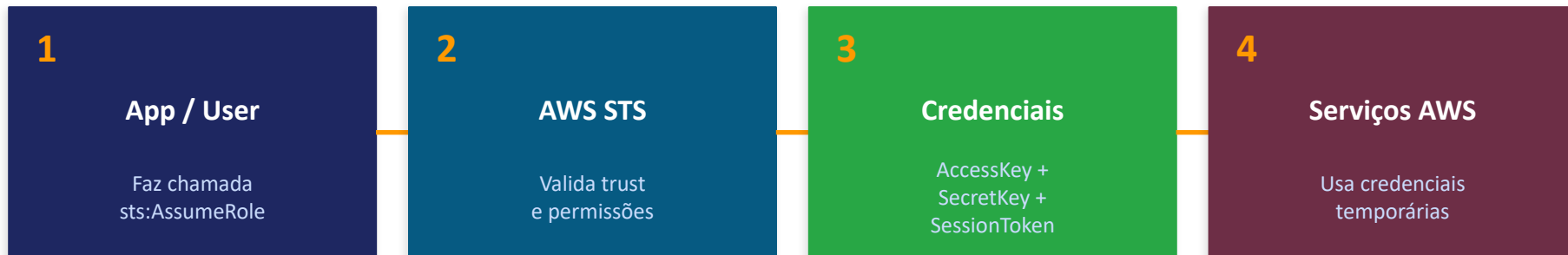
AWS STS: Security Token Service

Serviço que gera credenciais temporárias (Access Key + Secret Key + Session Token) com duração configurável. Substitui o uso de credenciais de longo prazo.

Principais APIs do STS:

AssumeRole	Assumir um role IAM (mesma conta ou cross-account) Duração: 15min - 12h. Retorna credenciais temporárias.	Duração: 15min - 12h
AssumeRoleWithWebIdentity	Login com IdP externo (Cognito, Google, Facebook) Substituído pelo Cognito Identity Pools na prática.	Substituído pelo Cognito Identity Pools na prática
AssumeRoleWithSAML	Federação com IdP corporativo via SAML 2.0 Integração com Active Directory, Okta, etc.	Integração com Active Directory, Okta, etc
GetSessionToken	Credenciais temporárias para usuário IAM com MFA Duração: 15min - 36h. Exige MFA token.	Duração: 15min - 36h
GetCallerIdentity	Retorna ARN, Account ID do caller atual Util para debugging e auditoria. Sem permissão especial.	Util para debugging e auditoria

Fluxo de AssumeRole: Passo a Passo



Trust Policy do Role (quem pode assumir):

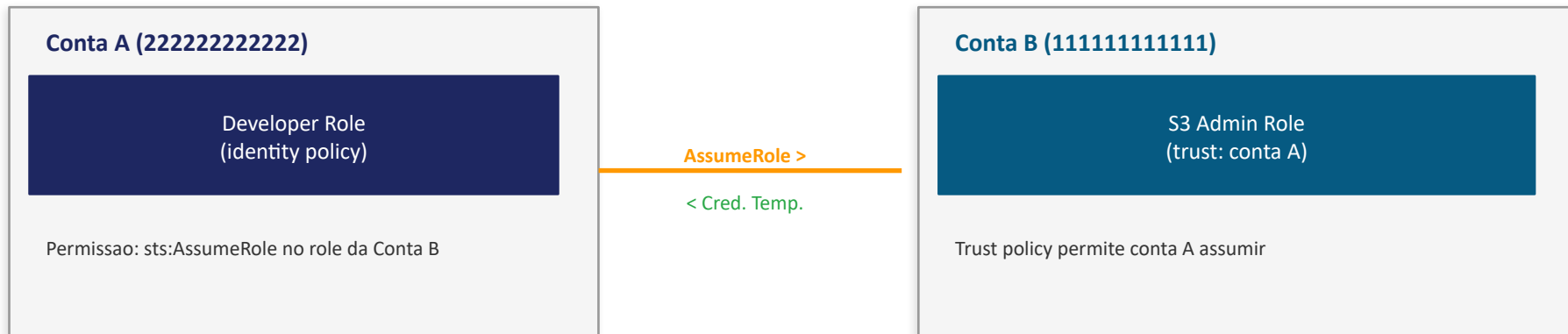
```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Principal": {
      "AWS": "arn:aws:iam::ACCOUNT:root"
    },
    "Action": "sts:AssumeRole"
  }]
}
```

Pontos críticos:

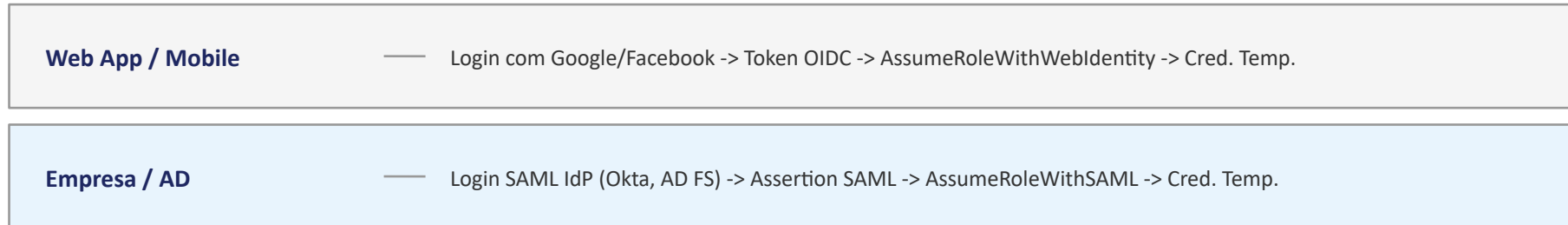
- Trust policy define QUEM pode assumir o role
- Permission policy define O QUE o role pode fazer
- Duração padrão: 1 hora (min 15min, max 12h)
- Session Token é OBRIGATÓRIO junto com as keys
- Suporta ExternalId para cross-account seguro
- Use `sts:SetSourceIdentity` para rastreabilidade

Casos: Cross-Account Access e Federação de Identidade

Cross-Account com AssumeRole:



Federacao de Identidade (AssumeRoleWithWebIdentity / SAML):



Boas Práticas e Cenários do Exame

Use AssumeRole quando:

- Acesso cross-account a recursos
- Aplicação EC2/Lambda precisa de permissões
- Delegar acesso temporário a terceiros
- Auditoria: toda ação é rastreável ao role

Evite credenciais de longo prazo:

- Nunca hardcode Access Keys no código
- Use IAM Roles para EC2, Lambda, ECS
- Use IAM Roles Anywhere para on-premises
- Prefira credenciais temporárias sempre

Cenários Críticos do Exame:

- EC2 precisa acessar S3: attach IAM Role na instancia (não use Access Keys)
- Lambda acessar DynamoDB: execution role com permissão DynamoDB
- Usuario externo (Google) acessar AWS: AssumeRoleWithWebIdentity ou Cognito Identity Pool
- ExternalId: use em cross-account para prevenir confused deputy attack

Pontos-chave para o Exame

1

STS gera credenciais temporárias

Access Key + Secret Key + Session Token. Session Token OBRIGATORIO. Duracao configuravel (15min a 12h para AssumeRole).

2

Trust Policy define quem assume

Sem trust policy correta, nenhuma chamada AssumeRole funciona. Diferente da permission policy do role.

3

Role em instancias = sem hardcode

EC2 e Lambda devem usar IAM Roles (instance profile / execution role). Nunca Access Keys hardcoded no código.

LEMBRE-SE: Recurso AWS precisa de permissao? -> IAM Role (nunca Access Key hardcoded). Cross-account? -> AssumeRole!